

DATABASE-RLS-MATRIX.md

MATRICE RLS — Vitala PostgreSQL Security Model

Version : V1

Statut : Référentiel officiel des politiques de sécurité RLS de Vitala

1. Objectif

La MATRICE RLS définit l'ensemble des règles d'accès aux données au niveau ligne (Row Level Security) dans PostgreSQL.

Elle constitue la source de vérité concernant :

- qui peut lire les données ;
- qui peut les modifier ;
- qui peut les supprimer ;
- dans quelles conditions ces opérations sont autorisées.

Son objectif est de garantir une sécurité stricte, cohérente et vérifiable sur toute la base de données Vitala.

2. Principes de sécurité

Toutes les politiques RLS reposent sur les principes suivants :

- **Deny by default** (aucun accès sans règle explicite)
 - **Least privilege** (accès minimal nécessaire)
 - **Ownership model** (les utilisateurs contrôlent leurs données)
 - **Domain isolation** (séparation stricte des domaines)
 - **Auditability** (toutes les actions doivent être traçables)
-

3. Structure de la matrice

La matrice RLS est organisée par table.

Chaque table contient les informations suivantes :

3.1 Informations générales

- Nom de la table
 - Domaine associé
 - Sensibilité des données
 - Type de protection RLS
-

3.2 Matrice des permissions

Pour chaque rôle, les permissions suivantes sont définies :

- SELECT
- INSERT
- UPDATE
- DELETE

Chaque permission peut être :

- AUTORISÉE
 - REFUSÉE
 - CONDITIONNELLE
-

3.3 Conditions RLS

Chaque règle doit préciser :

- la clause `USING`
 - la clause `WITH CHECK`
 - les conditions métier associées
-

3.4 Rôles système

Les rôles suivants peuvent être utilisés :

- authenticated
- anon
- service_role
- admin
- system
- edge_function

Chaque rôle doit être explicitement justifié.

4. Exemple de matrice (modèle)

Table : profiles

Rôle	SELECT	INSERT	UPDATE	DELETE
authenticated	YES (own data)	YES	YES (own data)	NO
admin	YES	YES	YES	YES
system	YES	YES	YES	YES
anon	NO	NO	NO	NO

Conditions

- SELECT : `user_id = auth.uid()`
- UPDATE : `user_id = auth.uid()`
- DELETE : interdit sauf admin

5. Règles globales

Toutes les tables métier doivent :

- avoir RLS activé ;
- définir explicitement leurs politiques ;
- éviter les accès implicites ;
- interdire l'accès anonyme par défaut.

6. Données sensibles

Les données sensibles incluent :

- identités utilisateur ;
- données personnelles ;
- contenus privés ;
- scores de confiance ;
- données de synchronisation ;
- historiques d'activité.

Ces données doivent être strictement protégées.

7. Exceptions

Toute exception aux règles RLS doit :

- être documentée ;
- être justifiée ;
- être validée par l'architecture ;
- être auditée.

Les exceptions temporaires doivent être supprimées après usage.

8. Audit et traçabilité

Toutes les opérations critiques doivent être :

- journalisées ;
 - traçables ;
 - associées à un utilisateur ou un service ;
 - conservées selon les règles d'audit.
-

9. Tests de sécurité

Chaque politique RLS doit être testée :

- accès autorisé ;
- accès interdit ;
- contournement impossible ;
- validation des rôles.

Les tests doivent être automatisés lorsque possible.

10. Cohérence avec l'architecture

La matrice RLS doit être cohérente avec :

- DATABASE-DICTIONARY.md ;
 - Domain Model ;
 - API Contracts ;
 - BUILD-SECURITY ;
 - Edge Functions ;
 - logique métier applicative.
-

11. Maintenance

Toute modification de la base de données doit entraîner :

- une mise à jour de la matrice ;
 - une validation des impacts ;
 - un test des politiques concernées.
-

12. Critères de conformité

Une table est conforme lorsque :

- RLS est activé ;
 - toutes les politiques sont définies ;
 - les rôles sont explicitement contrôlés ;
 - les tests de sécurité passent avec succès.
-

13. Conclusion

La MATRICE RLS constitue le cœur du modèle de sécurité PostgreSQL de Vitala.

Elle garantit une protection stricte des données, une séparation claire des accès et une architecture sécurisée par conception, indispensable à la fiabilité et à la confiance du système.